

Guía Detallada de los 93 Controles ISO/IEC 27001:2022

El Anexo A de la norma ISO/IEC 27001:2022 organiza sus 93 controles en 4 categorías principales enfocadas en mitigar riesgos de seguridad. A continuación se presenta el desglose estructurado de cada control por dominio.

1. Controles Organizativos (A.5) - 37 Controles

Ref	Nombre del Control	Descripción / Objetivo de Control
A.5.1	Políticas para la seguridad de la información	Definir, aprobar y revisar las directrices de seguridad de la organización.
A.5.2	Roles y responsabilidades en seguridad	Asignar claramente quién es responsable de cada área y activo de información.
A.5.3	Segregación de funciones	Separar tareas conflictivas para reducir riesgos de fraude o error no autorizado.
A.5.4	Responsabilidades de la dirección	Asegurar el compromiso activo de la gerencia con la seguridad corporativa.
A.5.5	Contacto con autoridades	Mantener canales de comunicación con la policía, entes reguladores y de gobierno.
A.5.6	Contacto con grupos de interés especial	Participar en foros y asociaciones profesionales de ciberseguridad.
A.5.7	Inteligencia de amenazas	Recopilar y analizar datos sobre amenazas actuales para prevenir ataques.
A.5.8	Seguridad en la gestión de proyectos	Integrar la seguridad de la información desde el inicio de cualquier proyecto.
A.5.9	Inventario de activos de información	Identificar y registrar todos los activos y fuentes de datos clave.
A.5.10	Uso aceptable de los activos	Establecer reglas claras sobre qué pueden hacer los empleados con los equipos.
A.5.11	Devolución de activos	Asegurar que el personal devuelva los dispositivos al finalizar su contrato.
A.5.12	Clasificación de la información	Etiquetar los datos según su criticidad (p. ej., público, confidencial).
A.5.13	Etiquetado de la información	Implementar marcas físicas o digitales que reflejen su clasificación.
A.5.14	Transferencia de información	Proteger los datos en tránsito mediante canales y acuerdos seguros.
A.5.15	Control de acceso	Restringir el acceso lógico a la información según la necesidad del negocio.
A.5.16	Gestión de identidades	Administrar el ciclo de vida completo de las cuentas de usuario.
A.5.17	Información de autenticación de usuario	Controlar la creación y asignación segura de contraseñas y credenciales.
A.5.18	Derechos de acceso	Asignar, modificar y revocar privilegios según el rol asignado.
A.5.19	Seguridad en relaciones con proveedores	Garantizar que terceros externos cumplan con los estándares de la empresa.
A.5.20	Seguridad en acuerdos con proveedores	Incluir cláusulas de confidencialidad y ciberseguridad en los contratos.
A.5.21	Cadena de suministro de TIC	Monitorear el riesgo tecnológico en proveedores de software y hardware.
A.5.22	Supervisión de servicios de proveedores	Evaluar continuamente que los proveedores mantengan su nivel de servicio.
A.5.23	Seguridad para servicios en la nube	Establecer criterios para la adquisición, uso y salida de la nube.
A.5.24	Gestión de incidentes: Planificación	Preparar la infraestructura y el personal para responder a fallos de seguridad.
A.5.25	Evaluación de eventos de seguridad	Determinar si una anomalía constituye un incidente de seguridad real.

A.5.26	Respuesta a incidentes	Ejecutar procedimientos para contener y mitigar los incidentes detectados.
A.5.27	Aprendizaje de incidentes	Analizar las causas raíz de los ataques para mejorar las defensas futuras.
A.5.28	Recopilación de evidencias	Preservar las pruebas forenses de forma válida para procesos legales.
A.5.29	Seguridad durante interrupciones	Garantizar la continuidad del negocio y la protección de datos ante desastres.
A.5.30	Preparación de TIC para continuidad	Asegurar la resiliencia y disponibilidad de los sistemas críticos.
A.5.31	Requisitos legales y regulatorios	Identificar y cumplir con leyes de protección de datos, propiedad intelectual, etc.
A.5.32	Derechos de propiedad intelectual	Implementar medidas para proteger software con licencia y derechos de autor.
A.5.33	Protección de registros	Almacenar y destruir los registros de la empresa bajo pautas legales.
A.5.34	Privacidad y protección de datos personales	Garantizar el cumplimiento normativo (como GDPR o normativas locales).
A.5.35	Revisión independiente de seguridad	Realizar auditorías internas o externas periódicas del SGSI.
A.5.36	Cumplimiento con políticas de seguridad	Verificar que los administradores y usuarios sigan las reglas internas.
A.5.37	Procedimientos operativos documentados	Mantener manuales e instrucciones claras para la operación de sistemas.

2. Controles de Personas (A.6) - 8 Controles

Ref	Nombre del Control	Descripción / Objetivo de Control
A.6.1	Investigación de antecedentes	Verificar antecedentes de candidatos antes del empleo (según leyes locales).
A.6.2	Términos y condiciones de empleo	Definir obligaciones de seguridad contractuales para empleados y contratistas.
A.6.3	Concientización y capacitación	Educar continuamente al personal en detección de phishing y buenas prácticas.
A.6.4	Proceso disciplinario	Establecer acciones formales ante violaciones a las políticas de seguridad.
A.6.5	Responsabilidades post-empleo	Mantener vigentes los acuerdos de confidencialidad tras la salida del empleado.
A.6.6	Acuerdos de confidencialidad	Firmar compromisos de no divulgación (NDA) con empleados y externos.
A.6.7	Teletrabajo	Implementar controles de seguridad específicos para el trabajo remoto.
A.6.8	Reporte de eventos de seguridad	Capacitar al personal para que notifique de inmediato debilidades o incidentes.

3. Controles Físicos (A.7) - 14 Controles

Ref	Nombre del Control	Descripción / Objetivo de Control
A.7.1	Perímetros de seguridad física	Proteger las instalaciones mediante barreras, muros, vallas o guardias.
A.7.2	Controles de entrada física	Restringir el acceso a oficinas mediante tarjetas, biometría o registros.
A.7.3	Seguridad de oficinas y salas	Diseñar áreas internas seguras para evitar espionaje o accesos indebidos.
A.7.4	Monitoreo de seguridad física	Supervisar las instalaciones mediante sistemas de alarma y cámaras CCTV.
A.7.5	Protección contra amenazas externas	Prevenir daños por incendios, inundaciones, explosiones o desastres naturales.
A.7.6	Trabajo en áreas seguras	Establecer reglas de conducta dentro de zonas con datos sensibles.
A.7.7	Escritorio y pantalla limpios	Evitar dejar papeles confidenciales o pantallas encendidas sin supervisión.
A.7.8	Emplazamiento y protección de equipos	Ubicar los servidores y hardware crítico en zonas protegidas del peligro.
A.7.9	Seguridad de los activos fuera de las instalaciones	Aplicar controles a dispositivos móviles y laptops usados fuera de la oficina.
A.7.10	Medios de almacenamiento	Gestionar de forma segura la reutilización, transporte y descarte de discos duros.
A.7.11	Suministro de servicios esenciales	Proteger los sistemas contra fallos de energía (UPS, generadores) o agua.
A.7.12	Seguridad del cableado	Proteger los cables de red y energía contra cortes o interceptaciones.
A.7.13	Mantenimiento de equipos	Realizar revisiones periódicas al hardware para asegurar su correcto funcionamiento.
A.7.14	Eliminación segura de activos	Destruir de forma definitiva la información antes de desechar equipos antiguos.

4. Controles Tecnológicos (A.8) - 34 Controles

Ref	Nombre del Control	Descripción / Objetivo de Control
A.8.1	Dispositivos de usuario final	Asegurar laptops y móviles con cifrado, antivirus y actualizaciones.
A.8.2	Derechos de acceso privilegiado	Restringir el uso de cuentas de administrador al mínimo necesario.
A.8.3	Restricción de acceso a la información	Limitar el acceso a los datos según el principio de menor privilegio.
A.8.4	Acceso al código fuente	Proteger los repositorios de desarrollo frente a lecturas o cambios indebidos.
A.8.5	Autenticación segura	Implementar contraseñas robustas y autenticación de doble factor (MFA).
A.8.6	Gestión de la capacidad	Monitorear el uso de discos, memoria y red para evitar caídas del sistema.
A.8.7	Protección contra malware	Instalar y mantener soluciones Endpoint (antivirus/EDR) actualizadas.
A.8.8	Gestión de vulnerabilidades técnicas	Escanear sistemas y aplicar parches de seguridad oportunamente.
A.8.9	Gestión de la configuración	Establecer líneas base de seguridad para servidores, redes y aplicaciones.
A.8.10	Eliminación de información	Borrar datos de forma segura cuando ya no sean requeridos normativamente.
A.8.11	Enmascaramiento de datos	Ocultar datos sensibles (como números de tarjeta) mediante anonimización.
A.8.12	Prevención de fuga de datos (DLP)	Implementar herramientas para evitar la salida no autorizada de archivos.
A.8.13	Respaldos de información (Backup)	Realizar y probar copias de seguridad de forma periódica fuera de línea.
A.8.14	Redundancia de instalaciones de TIC	Diseñar sistemas con alta disponibilidad para evitar puntos únicos de fallo.
A.8.15	Registro de eventos (Logging)	Guardar logs de actividad de usuarios y sistemas para auditorías.
A.8.16	Actividades de monitoreo	Supervisar redes y sistemas en tiempo real frente a comportamientos anómalos.
A.8.17	Sincronización del reloj	Alinear la hora de todos los servidores (NTP) para correlacionar logs.
A.8.18	Uso de programas de utilidad privilegiados	Limitar el software capaz de anular controles del sistema operativo.
A.8.19	Instalación de software en sistemas en producción	Controlar qué aplicaciones se instalan en entornos operativos.
A.8.20	Seguridad en redes	Proteger las redes corporativas frente a accesos no autorizados.
A.8.21	Seguridad de los servicios de red	Garantizar niveles de seguridad en conexiones como VPN o enlaces dedicados.
A.8.22	Segregación de redes	Dividir la red en segmentos (p. ej., separar red de invitados de la interna).
A.8.23	Filtrado web	Bloquear el acceso a sitios web maliciosos o inapropiados corporativamente.
A.8.24	Uso de la criptografía	Definir políticas de cifrado para datos en reposo y en tránsito.
A.8.25	Ciclo de vida del desarrollo seguro	Establecer reglas de seguridad para el desarrollo interno de software.
A.8.26	Requisitos de seguridad en aplicaciones	Definir qué protección necesita una app antes de desarrollarla o comprarla.

A.8.27	Principios de arquitectura e ingeniería seguras	Diseñar sistemas bajo arquitecturas sólidas (p. ej., Zero Trust).
A.8.28	Codificación segura	Capacitar a desarrolladores para evitar fallos comunes (OWASP Top 10).
A.8.29	Pruebas de seguridad en desarrollo	Realizar análisis de código (SAST/DAST) y pruebas de penetración.
A.8.30	Desarrollo tercerizado	Supervisar que el software encargado a externos cumpla con los estándares.
A.8.31	Separación de entornos	Dividir estrictamente los ambientes de Desarrollo, Pruebas y Producción.
A.8.32	Gestión de cambios	Controlar de forma estricta cualquier modificación en sistemas productivos.
A.8.33	Información de prueba	Evitar el uso de datos reales de clientes en entornos de desarrollo o prueba.
A.8.34	Protección de sistemas de información en auditorías	Minimizar el impacto de las herramientas de auditoría en los sistemas.